FlashTalk 007

Zero Trust - was ist das ?

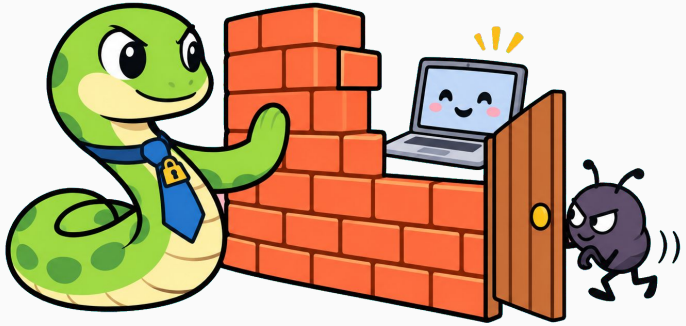
Die grosse Firewall

Früher: Außen böse, innen gut.

Firewalls schützen weiterhin den Eingang.

Doch was passiert, wenn ein Angreifer bereits im Netzwerk ist?

Dann reicht die Firewall allein nicht mehr.



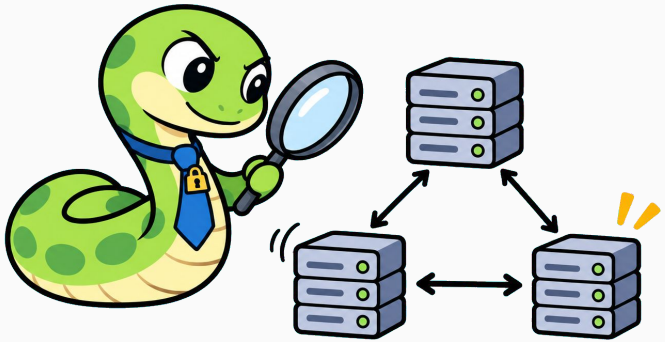
Viele Services, viele Abhängigkeiten

Anwendungen bestehen heute aus vielen voneinander abhängigen Diensten.

Diese Dienste kommunizieren ständig miteinander.

Vertrauen darf dabei nicht automatisch entstehen.

Jeder Aufruf muss seine Identität nachweisen.

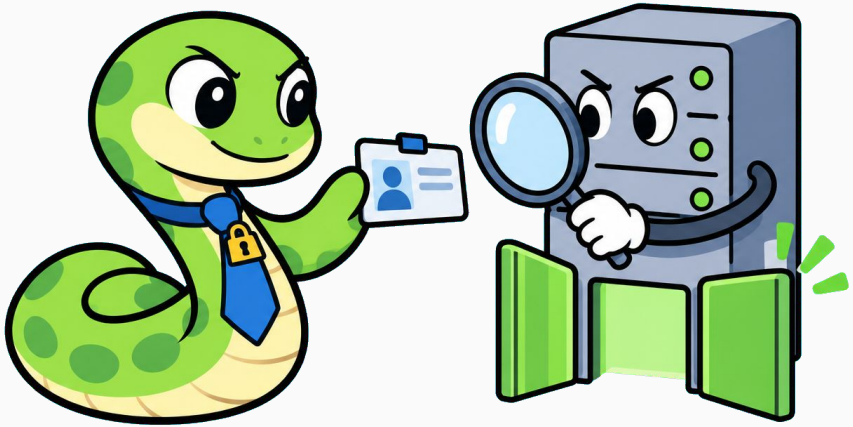


Die Lösung - Identität

Früher vertraute man Netzwerken.

Heute vertraut man Identitäten.

Jedes System muss beweisen, wer es ist.



Die Spur der Requests

Step 1

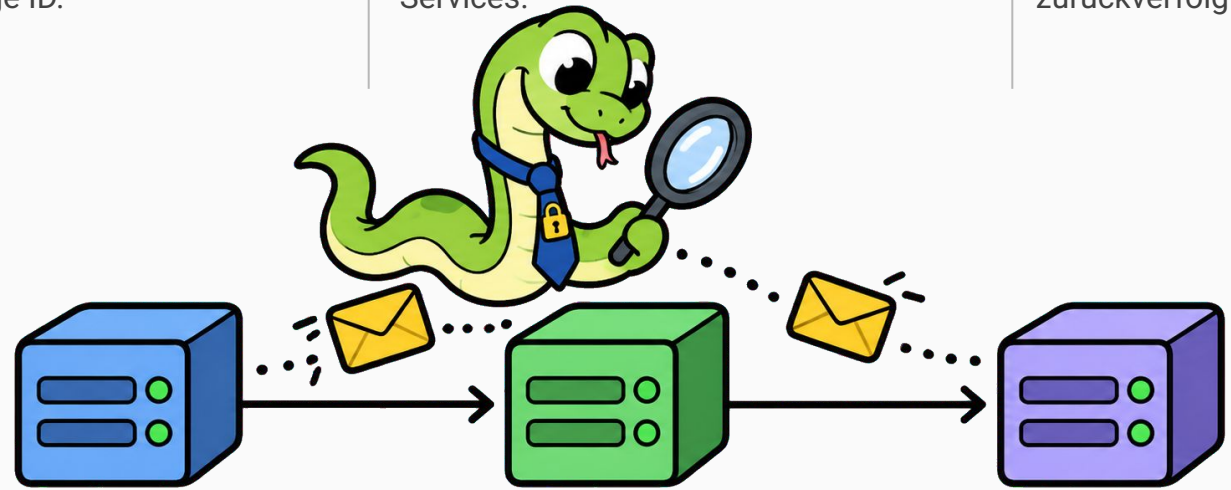
Jeder Request bekommt eine eindeutige ID.

Step 2

Die ID begleitet den Request durch alle Services.

Step 3

Probleme können schnell bis zur Ursache zurückverfolgt werden.



Fazit



Zero Trust bedeutet nicht:
"Niemandem vertrauen."

Zero Trust bedeutet:
"Immer überprüfen."


Now, who is who ?

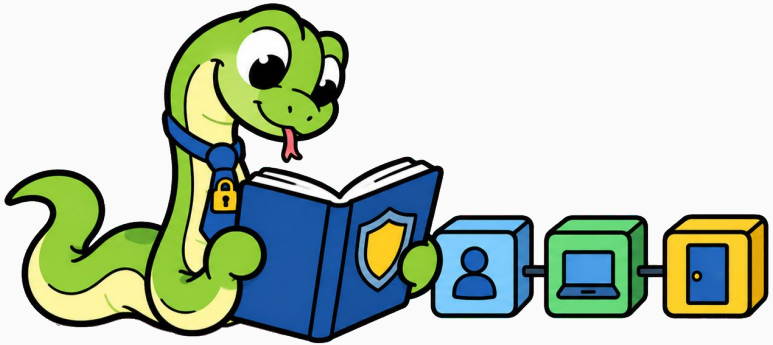
NIST

Das Regelwerk, das beschreibt, wie Zero Trust aufgebaut werden kann.

Zero Trust ist kein Herstellerprodukt und keine einzelne Software.

Das Konzept wurde vom NIST (National Institute of Standards and Technology) beschrieben und standardisiert.

Die Grundidee: Vertrauen entsteht nicht durch Netzwerkgrenzen, sondern durch kontinuierliche Überprüfung von Identitäten, Geräten und Zugriffen.



Conditional Access

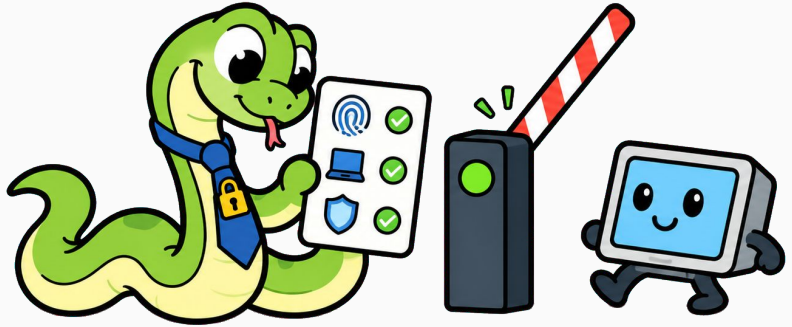
Zugriff ja, aber nur unter den richtigen Bedingungen.

Eine erfolgreiche Anmeldung allein reicht nicht immer aus.

Zusätzliche Bedingungen können sein:

- Multi-Faktor-Authentifizierung
- Verwaltetes Gerät
- Bekannter Standort
- Geringes Risikoprofil

So wird nicht nur geprüft, wer jemand ist, sondern auch unter welchen Umständen ein Zugriff erfolgt.



Token

Der digitale Ausweis einer Identität.

Nach einer erfolgreichen Anmeldung erhält ein Benutzer oder Service ein Token. Dieses Token enthält Informationen über die Identität und die erlaubten Berechtigungen.

Anwendungen können damit prüfen:

- Wer stellt die Anfrage?
- Welche Rechte hat die Identität?
- Ist die Anfrage noch gültig?



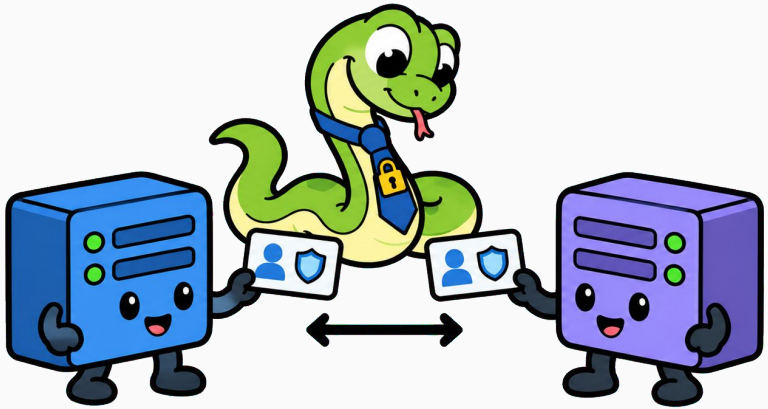
mTLS

Beide Seiten zeigen

Ausweis, nicht nur eine.

Bei einer normalen TLS-Verbindung weist sich üblicherweise nur der Server aus. Bei Mutual TLS (mTLS) authentifizieren sich beide Kommunikationspartner gegenseitig.

Gerade bei servicebasierten Architekturen ist mTLS ein wichtiger Baustein für Zero Trust.



Vertrauen ist gut, aber Zero Trust ist besser !

